

Security+ 5.1 · Security Policies

Mestre CyberSec · Aula 5.1 — Security Policies (11:02) · [Assistir Vídeo no YouTube](#) · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Policies = o QUE deve ser feito (top-level); Standards = o HOW (mais técnico); Procedures = o passo-a-passo. AUP (acceptable use policy): o que o usuário pode fazer. BCP (business continuity plan)/DRP (disaster recovery plan) = continuidade do negócio.

💡 Highlights que a prova CompTIA cobra

- Policy: o 'o quê'. Standard: o 'como'. Procedure: o passo-a-passo
- AUP: o que o usuário PODE fazer com recurso corporativo

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'high-level document stating what to protect'=policy

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Política (N/A)

Documento obrigatório de alto nível que declara o que a organização deseja proteger e seus objetivos gerais de segurança; não especifica implementação técnica.

⚠ **Armadilha CompTIA:** Se a questão pedir 'high-level document stating what to protect', a resposta é policy. Não confunda com standard (como) ou procedure (passo a passo).

• Padrão (N/A)

Documento técnico obrigatório que define requisitos, regras ou baselines específicos para implementar uma política.

⚠ **Armadilha CompTIA:** Standard = 'como' técnico e mensurável. Se a questão citar configuração específica, criptografia AES-256 ou senha mínima, provavelmente é standard.

• Procedimento (N/A)

Documento obrigatório, passo a passo, que descreve exatamente como executar uma tarefa ou processo específico conforme políticas e padrões.

⚠ **Armadilha CompTIA:** Procedure = passo a passo operacional. Se a questão descreve uma sequência de ações a serem executadas, é procedure.

• Diretrizes (N/A)

Recomendações ou melhores práticas não obrigatórias que ajudam usuários e administradores a cumprir políticas e padrões.

⚠ **Armadilha CompTIA:** Guidelines são recomendadas, mas não obrigatórias. Se a questão disser 'best practice' ou 'não obrigatório', não é policy nem standard.

• Política de Uso Aceitável (AUP)

Política que define o que os usuários podem e não podem fazer com recursos de TI corporativos, incluindo e-mail, internet e dispositivos.

⚠ **Armadilha CompTIA:** AUP = o que o usuário PODE fazer com recurso corporativo. Frequentemente exige assinatura ou ciência do funcionário. Não é BCP nem DRP.

• Plano de Continuidade de Negócios (BCP)

Plano que garante que funções críticas de negócio continuem durante e após uma interrupção, focando na resiliência de toda a organização.

⚠ **Armadilha CompTIA:** BCP = continuidade do negócio como um todo. Se a questão fala em manter operações críticas durante um desastre, é BCP. DRP é recuperação de TI.

• Plano de Recuperação de Desastres (DRP)

Plano focado em recuperar infraestrutura de TI, sistemas e dados após um desastre, incluindo procedimentos de restauração e objetivos de tempo de recuperação.

⚠ **Armadilha CompTIA:** DRP = recuperação técnica de TI após desastre. Não confunda com BCP, que é mais amplo e focado no negócio. DRP costuma vir após o BCP.

Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Uma empresa de serviços financeiros tem um novo requisito da liderança executiva: todos os registros financeiros de clientes devem ser protegidos com criptografia forte onde quer que sejam armazenados ou transmitidos. O arquiteto de segurança deve criar o documento que declara esse requisito obrigatório de alto nível. Que tipo de documento deve ser criado?

- A) Política de uso aceitável
- B) Política de segurança
- C) Padrão técnico
- D) Procedimento operacional

QUESTÃO 2 · CENÁRIO DE EXAME

Após aprovar o requisito de que todos os dados sensíveis devem ser criptografados, a equipe de segurança deve especificar algoritmos aprovados, tamanhos mínimos de chave e protocolos para servidores, bancos de dados e dispositivos móveis. Qual documento eles devem publicar?

- A) Diretriz
- B) Procedimento
- C) Padrão
- D) Plano de continuidade de negócios

QUESTÃO 3 · CENÁRIO DE EXAME

A equipe de suporte deve garantir que a conta de todo funcionário desligado seja desativada em até 30 minutos, incluindo etapas para verificar o chamado, contatar o gerente, desativar a conta do Active Directory, revogar o acesso VPN e documentar a conclusão. Qual documento a equipe deve seguir?

- A) Política de uso aceitável
- B) Padrão técnico
- C) Procedimento
- D) Diretriz

QUESTÃO 4 · CENÁRIO DE EXAME

Uma empresa deseja fornecer recomendações não obrigatórias aos funcionários sobre usar senhas fortes e exclusivas, ativar bloqueio de tela e evitar Wi-Fi público para trabalho sensível. Essas recomendações não são exigíveis, mas refletem boas práticas. Qual tipo de documento é mais apropriado?

- A) Política
- B) Padrão
- C) Procedimento
- D) Diretriz

QUESTÃO 5 · CENÁRIO DE EXAME

Um funcionário instala um aplicativo de compartilhamento de arquivos ponto a ponto em um laptop corporativo para baixar filmes e também usa a conta de e-mail corporativa para enviar conselhos de investimento pessoais aos colegas. O RH pergunta qual documento define mais diretamente quais atividades pessoais são permitidas nos sistemas da empresa. Qual documento o RH deve consultar?

- A) Plano de recuperação de desastres
- B) Política de uso aceitável
- C) Plano de continuidade de negócios
- D) Padrão de criptografia

QUESTÃO 6 · CENÁRIO DE EXAME

Um hospital regional sofre uma queda de energia prolongada. Os líderes clínicos precisam de uma abordagem documentada para continuar admissões de pacientes, rastreamento de medicamentos em papel e rotação de equipe até a energia ser restaurada, mesmo que os sistemas de TI estejam indisponíveis. Qual plano eles devem ativar?

- A) Plano de recuperação de desastres
- B) Plano de resposta a incidentes
- C) Plano de continuidade de negócios
- D) Plano de gerenciamento de vulnerabilidades

QUESTÃO 7 · CENÁRIO DE EXAME

Um ataque de ransomware criptografa o data center principal. A equipe de TI precisa de etapas documentadas para reconstruir servidores, restaurar backups, validar a integridade dos dados e fazer failover para o site em nuvem dentro do objetivo de tempo de recuperação. Qual plano eles devem usar?

- A) Plano de continuidade de negócios
- B) Plano de recuperação de desastres
- C) Política de uso aceitável
- D) Política de conscientização de segurança

QUESTÃO 8 · CENÁRIO DE EXAME

O CIO de uma empresa quer garantir que a organização possa continuar processando folha de pagamento e pedidos de clientes durante uma interrupção, e solicitou um plano que identifique funções críticas de negócio, dependências e alternativas manuais. Qual documento o CIO está solicitando?

- A) Plano de continuidade de negócios
- B) Plano de recuperação de desastres
- C) Padrão de codificação segura
- D) Política de uso aceitável

QUESTÃO 9 · CENÁRIO DE EXAME

O gerente de segurança está revisando documentos de governança. Um documento afirma que senhas devem ter pelo menos 14 caracteres, MFA é obrigatório para acesso remoto, e TLS 1.2 ou superior deve ser usado. O documento não explica como configurar os sistemas. Que tipo de documento é este?

- A) Política
- B) Padrão
- C) Procedimento
- D) Diretriz

QUESTÃO 10 · CENÁRIO DE EXAME

Uma organização está elaborando um documento que descreve etapas obrigatórias para responder a um smartphone corporativo perdido: notificar a segurança, apagar o dispositivo remotamente, redefinir credenciais, documentar o incidente e notificar o encarregado de privacidade se dados sensíveis estiverem envolvidos. Que tipo de documento está sendo elaborado?

- A) Diretriz
- B) Padrão
- C) Procedimento
- D) Plano de continuidade de negócios

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa B — Política de segurança

A política de segurança é a escolha correta porque expressa a intenção obrigatória de alto nível e os princípios da gestão. Um padrão técnico definiria algoritmos ou tamanhos de chave específicos, um procedimento forneceria instruções passo a passo, e uma política de uso aceitável governa o comportamento do usuário, não requisitos de proteção de dados.

Questão 2: Alternativa C — Padrão

Um padrão é correto porque fornece requisitos técnicos específicos e obrigatórios que apoiam uma política. Uma diretriz é recomendada e não obrigatória, um procedimento é a execução passo a passo, e um plano de continuidade de negócios trata da manutenção das funções de negócio durante interrupções.

Questão 3: Alternativa C — Procedimento

Um procedimento é correto porque fornece as ações ordenadas, passo a passo, necessárias para concluir uma tarefa operacional específica. Uma AUP define o comportamento permitido do usuário, um padrão define requisitos técnicos obrigatórios, e uma diretriz oferece recomendações não obrigatórias.

Questão 4: Alternativa D — Diretriz

Uma diretriz é correta porque contém boas práticas recomendadas que não são obrigatórias. Uma política é uma intenção obrigatória de alto nível, um padrão contém requisitos técnicos obrigatórios, e um procedimento descreve ações obrigatórias passo a passo.

Questão 5: Alternativa B — Política de uso aceitável

Uma política de uso aceitável é correta porque define o que os usuários podem e não podem fazer com sistemas, redes e dados organizacionais. DRP e BCP tratam de recuperação e continuidade, enquanto um padrão de criptografia especifica controles criptográficos.

Questão 6: Alternativa C — Plano de continuidade de negócios

Um plano de continuidade de negócios é correto porque se concentra em sustentar funções críticas de negócio durante uma interrupção. Um plano de recuperação de desastres foca na restauração de sistemas de TI e dados, enquanto resposta a incidentes e gerenciamento de vulnerabilidades tratam de eventos de segurança e fraquezas.

Questão 7: Alternativa B — Plano de recuperação de desastres

Um plano de recuperação de desastres é correto porque fornece procedimentos focados em TI para restaurar sistemas, dados e infraestrutura após um evento disruptivo. Um BCP mantém as funções de negócio durante o evento, enquanto AUP e políticas de conscientização tratam do comportamento do usuário e treinamento.

Questão 8: Alternativa A — Plano de continuidade de negócios

Um plano de continuidade de negócios é correto porque identifica funções críticas de negócio e como mantê-las operando durante interrupções. Um DRP é mais restrito e foca na restauração da infraestrutura de TI, enquanto um padrão de codificação segura e uma AUP tratam de controles de desenvolvimento e comportamento do usuário.

Questão 9: Alternativa B — Padrão

Um padrão é correto porque contém requisitos técnicos específicos e obrigatórios, como comprimento de senha, MFA e versões de TLS. Uma política é uma intenção mais ampla, um procedimento explica como implementar configurações passo a passo, e uma diretriz é orientação não obrigatória.

Questão 10: Alternativa C — Procedimento

Um procedimento é correto porque especifica as etapas ordenadas para executar uma tarefa específica. Uma diretriz é orientação opcional, um padrão define requisitos técnicos obrigatórios, e um BCP trata da continuidade das funções de negócio durante interrupções.